Unit 5- Q1 - Describe how legislation impacts on cyber security

NOTE:

Legislation: Your description must cover a minimum of four pieces of legislation.

Examples include, but are not limited to the following:

• Computer Misuse Act 1990

• Official Secrets Act 1989

• Communications Act 2003

• Data Protection Act 2018/UK General Data Protection Regulation (UK GDPR)

• Police and Criminal Evidence Act 1984 (PACE)

• Directive on security of network and information systems (2016/1148) (known as the NIS Directive).

Note that the above will change or be replaced over time, and it is important that current and relevant legislation is covered.

Legislation has an important impact on cyber security because it sets out what individuals and organizations are legally required to do when using computers, networks, and personal info. It helps protect people from cybercrime, encourages organizations to secure their systems, and provides legal consequences when the rules are broken.

1.Computer Misuse Act 1990 (CMA)

The CMA makes it illegal to access computers systems or data without permission. It also covers unauthorised changes to data, such as deleting files, installing malware, or damaging a network. This means that organizations must protect their systems against unauthorised access, while cyber security professionals must make sure they have permission before caring out penetration testing or other security checks. The Act helps protect computer systems from hackers and people who may deliberately cause damage.

2.Data Protection Act 2018 (DPA) and UK GDPR

The DPA 2018 works alongside the UK GDPR to protect personal info, such as names, addresses and financial details. Orgnisations must handle personal data lawfully and keep it secure. They should use appropriate security measures, such as firewalls, antivirus software, access controls, and clear security policies. They must also make sure that personal info is accurate only kept for as long as necessary and only accessed by authorized people. Failing to protect personal data can lead to enforcement action and significant fines.

3.Network & Information Systems (NIS) Regulations 2018

The NIS Regulations focus on protecting important networks and information systems. They apply to certain essential service operations and digital service providers, requiring them to take appropriate and proportionate steps to manage cyber incidents and reduce the impact of cyber security incidents. Companies need to understand the risk they face and put suitable protective measures in. This helps improve the reliability of important services and reduces the chance of cyber-attacks causing serious disruption.

4. Official Secrets Act 1989
The OSA protects sensitive government info, including information relating to national security, defense, and intelligence. It makes certain untheorized disclosure of protected info a criminal offence. This affects security because people working with sensitive government info must keep it confidential and prevent unauthorised access or discloser. Security measures such as restricted access, secure storage and safe handling of info help reduce risk of confidential data being leaked.
5.Communication Act 2003
The CA 2003 includes rules relating to the use of electronic communication networks. Section 127 covers certain messages that are grossly offensive, indecent, obscene, or menacing when sent through a public electronic communication network. This is relevant to online safety because it can make certain forms of abusive or threatening electronic communication a criminal offence. It reminds people that using the internet does not mean they are free from legal responsibility for what they sent or published.

Unit 5- Q2 - Explain trends in international law for cyberspace

NOTE:

You should give a basic explanation of the trends within international law for cyberspace.

International law increasingly applies to cyberspace with a focus on state responsibility, cyber norms, treaty development, and adoption of existing legal principles to digital operations. (ADD MORE)

Unit 5- Q3 - Identify ISO standards related to cyber security

NOTE:

ISO standards, for example:

• ISO/IEC 27032:2012

• ISO/IEC 27000:2018

• ISO/IEC 27001:2013.

Note that the above will change or be replaced over time, and it is important that current and relevant standards are covered.
ISO/IEC 27032- standers that provide high level recommendations for internet security.

ISO/IEC 27000- family of standers that hep company manage information security

ISO/IEC 27001- standard for managing information security

ISO/IEC 27002- code of practice for information security controls

ISO/IEC 27003- information security management system implementation guidance

ISO/IEC 27004- minting, measurements, analysis, and evaluating information security systems.

ISO/IEC 27005- information security risk management

ISO/IEC 270 10- information security management for inter-sector and inter-organizational communication

ISO/IEC 27011- information security management guidance for telecommunication organizations

Unit 5- Q4 - Explain how ISO standards are used to support cyber security

ISO standers are internarial recognized guidelines that help companies establish consistent effect for information security. They also provide a systematic approach to identifying assessing risk to digital assets to ensure the confidentiality of integrity and availability of information. By adopting ISO standers organizations can implement polices procedures and controls that address vulnerabilities prevent unorthernized accesses which also allows for effective responses to cyber incidents



Unit 5- Q5 - Describe ethical conduct within cyber security

NOTE:

Ethical conduct must include, but is not limited to:

• maintaining confidentiality

• adherence to applicable laws • promoting information security • refraining from conflicts of interest.

Ethical conduct in cybersecurity involves adhering to moral principles and professional standards to protect data, systems and networks whiles keeping in mind privacy, fairness, and responsibility.

Core principles are:

Respect of privacy- must ensure that adequate proportions are taken when working with personal sensitive data that is collected, stored and used responsibly, with consent and care, avoiding unorthernized access or misuse of info.

Transparency- Organizations should be open about the security practices & potential risk and how data is handled.

Accountability- professionals are responsible for their actions including security breaches or failures and must take the proper steps to mitigate harm and report any incidents.

Integrity & honesty- ethical conduct requires honest reporting vulnerabilities and compliance with laws and must avoid exploiting weaknesses for personal gain.

Unit 5- Q6 - Identify unethical conduct within cyber security

NOTE:

Unethical conduct must include, but is not limited to:

• sabotage

• disclosing or misusing confidential information • maliciously injuring the reputation or prospects of an individual or business.

Unethical conduct in cybersecurity involves unauthorized systems of access, misuse of privileged data breach, and malicious hacking and data theft.

Forms of unethical conduct:

Unauthorized access & Data misuse: accessing systems, files or coms without permission, access to view employee or customer data beyond what's necessary, exploiting vulnerabilities for personal gain rather than reporting them.

Malicious Hacking (Black Hat): breaking into networks to steel data, disrupting operations or deploying malware, conducting phishing or social engineering attacks to obtain credentials, selling stolen data or extorting victims.

Unethical Penetration Testing: conducting tests without proper authorization, using hacking tools irresponsonsibley or beyond agreed scope, failing to follow ethical boundaries in vulnerability.